

Foundations of Vulnerabilities & Patches



Vulnerability Management

- Vulnerabilities
- CVSS
- Zero Day Vulnerability
- Case Study: Moveit Vulnerability

Labs:

- Students will perform vulnerability scanning of a given vulnerable machine and export the results

Vulnerabilities

- A vulnerability is a weakness, flaw, or misconfiguration in a system, application, network, or process that can be exploited by a threat actor to compromise confidentiality, integrity, or availability.
- Vulnerabilities may exist in:
 - Operating systems
 - Applications and databases
 - Network devices and protocols
 - Cloud configurations
 - Human processes and policies
- A vulnerability does not cause harm by itself; risk materializes only when it is exploited by a threat.



Vulnerability vs Threat vs Risk

Term	Meaning
<i>Vulnerability</i>	Weakness
<i>Threat</i>	Potential attacker or event
<i>Risk</i>	Likelihood × Impact
<i>Exploit</i>	Method used to abuse vulnerability

Common Types of Vulnerabilities

▪ **Software Vulnerabilities**

- Buffer overflows
- SQL injection
- Cross-site scripting (XSS)
- Insecure deserialization
- Hard-coded credentials

▪ **Configuration Vulnerabilities**

- Open ports and services
- Weak firewall rules
- Default credentials
- Excessive permissions

▪ **Network Vulnerabilities**

- Unencrypted protocols
- Weak Wi-Fi security
- Flat network architecture
- Missing network segmentation

▪ **Operating System Vulnerabilities**

- Missing patches
- Outdated OS versions
- Insecure registry settings
- Weak local policies

Common Types of Vulnerabilities

▪ **Cloud and Container Vulnerabilities**

- Publicly exposed storage
- Over-permissive IAM roles
- Insecure APIs
- Unpatched container images

▪ **Identity and Access Vulnerabilities**

- Weak passwords
- Lack of MFA
- Privilege creep
- Orphaned accounts

▪ **Process and Human Vulnerabilities**

- Poor security awareness
- Weak incident response procedures
- Lack of segregation of duties

Vulnerability Lifecycle



Common Vulnerability Scoring System (CVSS)

- CVSS scores vulnerabilities from 0.0 to 10.0:

Score	Severity
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

Vulnerability Assessment vs Penetration Testing

Aspect	Vulnerability Assessment	Penetration Testing
<i>Purpose</i>	Identify weaknesses	Exploit weaknesses
<i>Depth</i>	Broad	Deep
<i>Frequency</i>	Regular	Periodic

Zero Day Vulnerability

- A Zero-Day Vulnerability is a previously **unknown security flaw** in software, hardware, or firmware that is not yet known to the vendor and for which **no official patch or fix exists** at the time it is discovered or exploited.
- The term “zero-day” refers to the fact that defenders have had zero days to prepare a mitigation.
- Key Characteristics of Zero-Day Vulnerabilities
 - ✓ Unknown to the vendor or public
 - ✓ No patch or signature available
 - ✓ High likelihood of successful exploitation
 - ✓ Often used in targeted and advanced attacks
 - ✓ Extremely valuable in underground markets



Zero-Day Vulnerability vs Zero-Day Exploit

Term	Meaning
Zero-Day Vulnerability	The security weakness itself
Zero-Day Exploit	The technique/code used to exploit it
Zero-Day Attack	An attack leveraging the exploit

How Zero-Day Vulnerabilities Are Discovered

- Security researchers
- Threat actors and APT groups
- Bug bounty programs
- Reverse engineering
- Fuzz testing
- Code analysis
- Discovery can be ethical (responsible disclosure) or malicious.



Common Targets of Zero-Day Vulnerabilities

- Operating systems (Windows, Linux)
- Browsers (Chrome, Edge)
- VPN and firewall appliances
- Email servers
- Enterprise applications
- Mobile OS (Android, iOS)

Mitigation and Defence Strategies

Preventive Controls

- Attack surface reduction
- Least privilege
- Application whitelisting
- Disable unnecessary services

Detection Controls

- EDR/XDR behavioral analysis
- Anomaly-based detection
- Memory and process monitoring
- Network traffic analysis

Containment Controls

- Network segmentation
- Privileged access management
- Rapid isolation of endpoints

Real-World Zero-Day Examples

- Microsoft Exchange ProxyLogon
- Log4Shell (Log4j)
- Chrome V8 zero-days
- VPN appliance zero-days

Case Study: MOVEit Transfer Vulnerability (2023)

- MOVEit Transfer is a secure managed file transfer (MFT) solution used to:
 - ✓ Transfer sensitive data securely
 - ✓ Support compliance (HIPAA, PCI DSS, GDPR)
 - ✓ Automate B2B file transfers
- It is often internet-facing, making it a high-value target.
- Summary of MOVEit Transfer (by Progress Software)
 - ✓ **Threat Actor:** CL0P (Clop) ransomware group
 - ✓ **Impact:** Large-scale data theft (extortion without encryption)
 - ✓ **Nature:** Zero-day SQL Injection vulnerability
 - ✓ **Affected Sector:** Government, BFSI, healthcare, education, enterprises



Attack Timeline

- **Phase 1: Zero-Day Discovery**

- CL0P identified an undisclosed SQL injection flaw
- No patch or signature existed at the time

- **Phase 2: Mass Exploitation**

- Automated scanning for exposed MOVEit servers
- Injection of malicious SQL payloads
- Deployment of a web shell (LEMURLOOT)

- **Phase 3: Data Exfiltration**

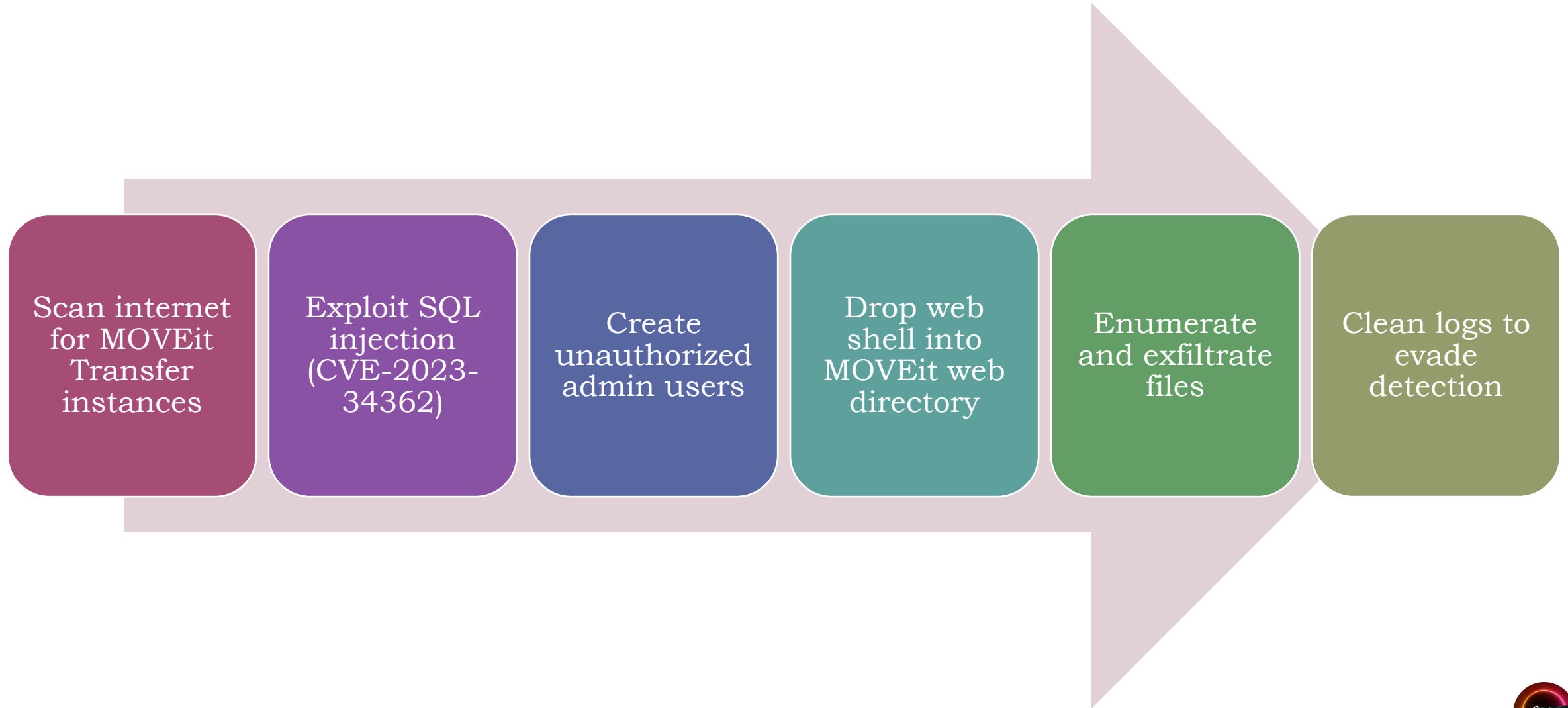
- Extraction of sensitive files:
 - PII
 - Financial data
 - Health records
- No encryption used (pure data theft)

- **Phase 4: Extortion**

- Victims contacted via dark web
- Threatened public data leaks
- Double extortion model

[Read More...](#)

Technical Attack Flow



Why This Attack Was So Effective

- Trusted third-party software
- Internet-facing deployment
- Zero-day nature
- High-value centralized data
- Lack of behavioral monitoring
- Over-reliance on perimeter security



Mitigation and Response Actions

- **Immediate Actions (Recommended)**

- Disconnect MOVEit servers from internet
- Apply emergency patches
- Rotate credentials
- Review logs for web shell activity

- **Long-Term Controls**

- Place MFT systems behind VPN/WAF
- Restrict internet exposure
- Enable EDR on servers
- Continuous vulnerability scanning



Key Lessons Learned

- Zero-trust must apply to third-party software
- Internet-facing systems need continuous monitoring
- Patch management alone is insufficient
- Behavioral detection is critical
- Data-centric security is essential





That's all Folks!